

OTERIA CYBER SCHOOL

Exploitation d'une chaîne SSRF → RCE

Audit interne — périmètre applicatif Cloudbox

Lisa HURTAUD • 12 septembre 2026
Version 1.2 — diffusion restreinte comité sécurité

- 01 Contexte et périmètre
- 02 Exploitation
- 03 Résultats

01

Contexte et périmètre

Le périmètre porte sur l'application de partage de fichiers et sur les services qu'elle interroge en interne. Trois environnements ont été testés, en boîte grise, entre le 2 et le 9 septembre.

14

vulnérabilités

3

critiques

92%

correctifs validés

! Sans filtrage de l'URL sortante

Le service de prévisualisation accepte n'importe quelle URL fournie par l'utilisateur. Un attaquant atteint le service de métadonnées du cloud et récupère des identifiants **valides pendant 6 heures**.

✓ Après mise en place de l'allow-list

Seuls trois domaines sont joignables. La tentative retourne un `403` et génère une alerte SIEM en **moins de 4 secondes**.

i Référentiel

ANSSI-PG-078, R29 — validation systématique des URL fournies par un tiers.

02

Exploitation

Python

```
1 import requests
2 from urllib.parse import urlparse
3
4 def fetch_preview(url: str) -> bytes:
5     """Récupère la miniature d'un document distant."""
6     parsed = urlparse(url) # aucun contrôle sur le schéma
7     if parsed.scheme not in ("http", "https"):
8         raise ValueError("schéma non supporté")
9     # L'hôte n'est jamais vérifié : SSRF possible
10    return requests.get(url, timeout=5).content
```

Le correctif, ligne par ligne

● ● ● preview/fetcher.py

Python

```
1 ALLOWED = {"cdn.cloudbox.internal", "static.cloudbox.io"}
2
3 def fetch_preview(url: str) -> bytes:
4     parsed = urlparse(url)
5     if parsed.hostname not in ALLOWED:
6         audit.log("ssrf_attempt", url=url)
7         raise PermissionError("hôte non autorisé")
8     return requests.get(url, timeout=5).content
```

```
●●● attaquant@kali
```

```
$ curl -s 'https://app.cloudbox.io/preview?u=http://169.254.169.254/latest/meta-data/iam/'  
AccessKeyId      : ASIA4XKMPLQ7ZC3RV2NE  
SecretAccessKey  : wJalr...  
Expiration       : 2026-09-08T14:22:31Z
```

Les identifiants obtenus donnent un accès en lecture au bucket de sauvegarde, soit **2,3 To de données clients**.

03

Résultats

Réf.	Vulnérabilité	Criticité	Statut
CBX-01	SSRF sur le service de prévisualisation	CRITIQUE	Corrigé
CBX-02	Jetons de session sans attribut <code>Secure</code>	HAUTE	Corrigé
CBX-03	Énumération d'utilisateurs sur <code>/login</code>	MOYENNE	Ouvert
CBX-04	En-tête <code>X-Frame-Options</code> absent	BASSE	Corrigé

CBX-01

CRITIQUE

SSRF sur le service de prévisualisation

L'absence de validation de l'hôte permet d'atteindre le service de métadonnées de l'hébergeur et d'obtenir des identifiants temporaires. Exploitation confirmée en environnement de recette, non rejouée en production.

Correctif — allow-list stricte, journalisation des tentatives, rotation des rôles IAM ramenée à 1 heure.

Le point d'entrée est public. Le service de prévisualisation, lui, se trouve dans le même sous-réseau que le point de métadonnées : rien ne les sépare.

- ▶ Passerelle publique
- ▶ Service de prévisualisation
- ▶ Point de métadonnées **joignable**

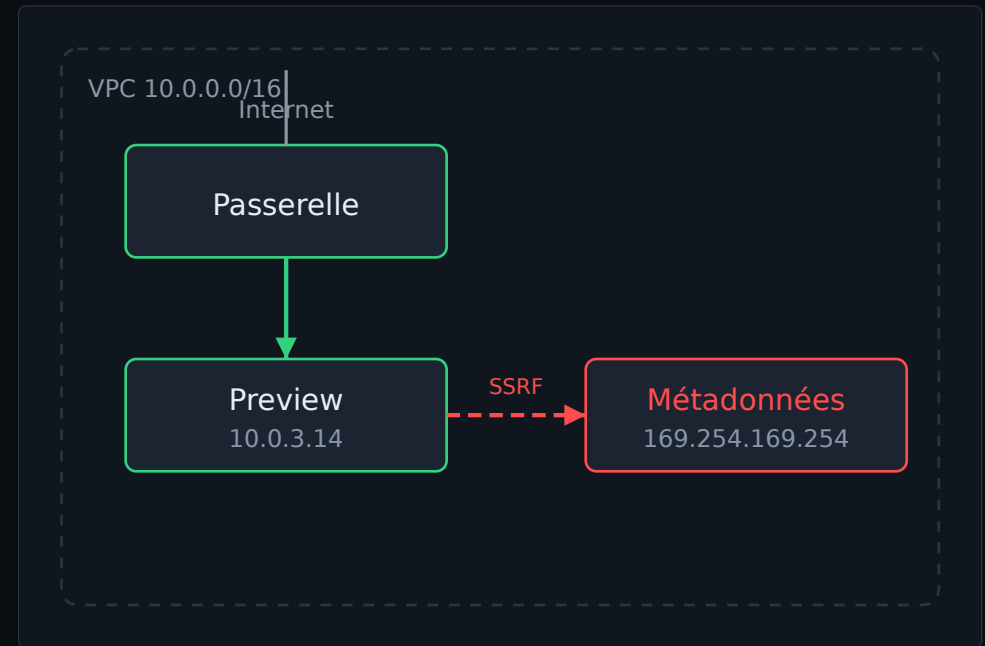


Fig. 1. – Chemin d'attaque reconstitué depuis les journaux

1. Segmenter le réseau du service de prévisualisation
2. Généraliser la revue de code sur les appels sortants
3. Rejouer le test après la migration prévue en novembre

Une allow-list n'est pas une défense en profondeur.

Questions ?

`lisa.hurtaud@example.org` — clé PGP : `9F2A 41C7 ... 0E5B`